

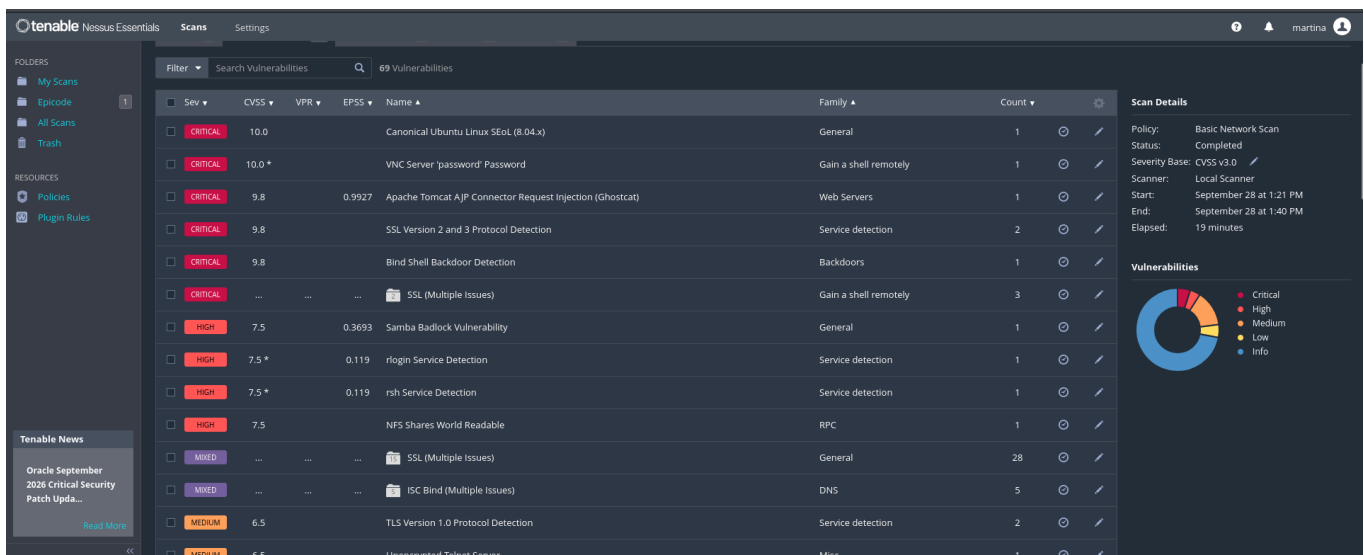
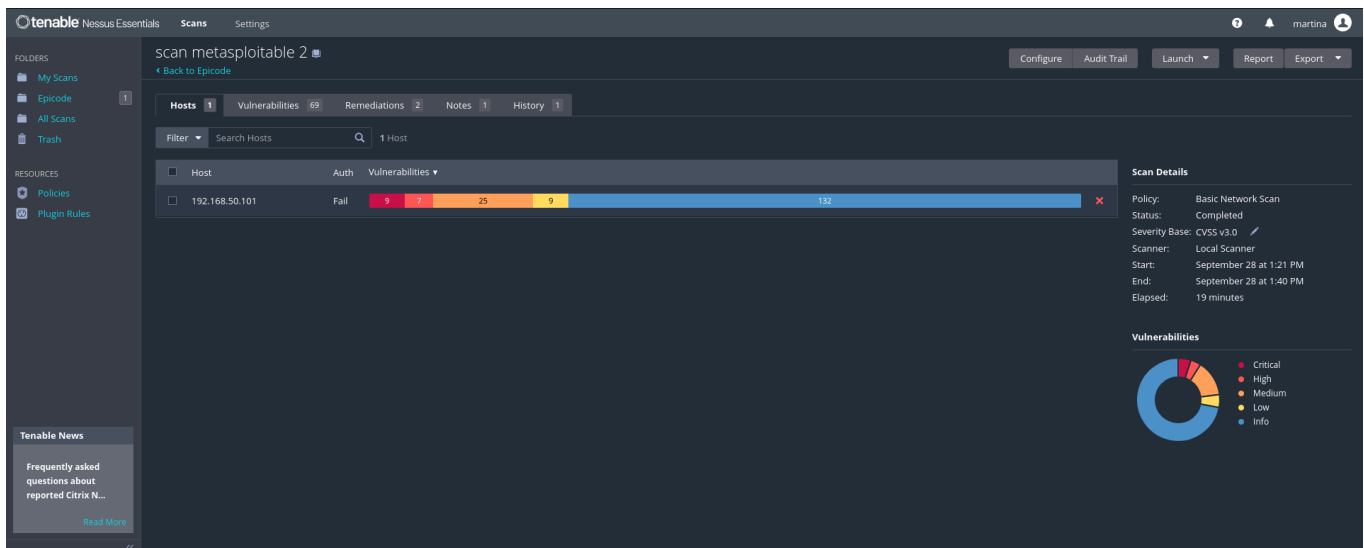
Nome: Martina Foresta
Corso: CyberSecurity
Attività: Nessus

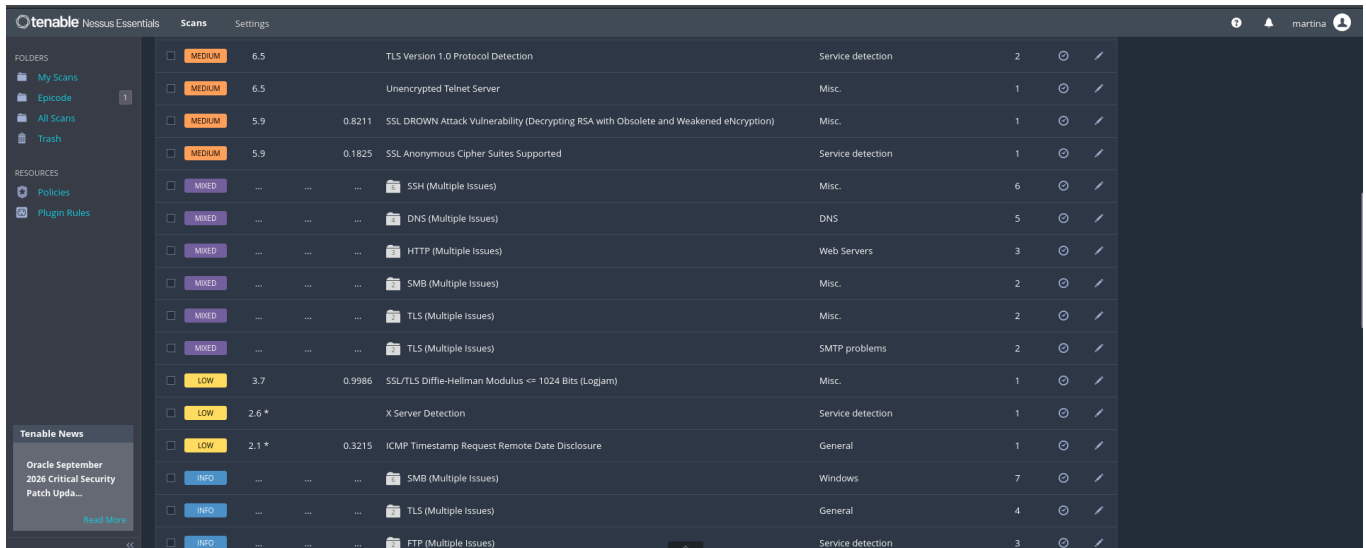
Vulnerabilità rilevate da Nessus - Metasploitable 2

Target: 192.168.50.101 (Metasploitable 2)

Scansione: Nessus Essentials, Basic Network Scan | 28 settembre 2026 | durata circa 19 minuti

Sistema identificato da Nessus: Linux kernel 2.6 su Ubuntu 8.04 (Hardy) | autenticazione: Auth Fail





Sintesi: cosa emerge dalla scansione

Nessus mostra 69 voci o gruppi nella scheda Vulnerabilities. Le schermate consentono di ricostruire 18 risultati individuali; le righe “Multiple Issues” raccolgono altri plugin ma non ne mostrano i nomi, le porte e le descrizioni singole. Il conteggio 69 non va quindi letto come 69 difetti distinti.

Il quadro è quello di un sistema molto datato con servizi legacy raggiungibili in rete. “Critical”, “High”, “Medium” e “Low” sono livelli di priorità assegnati ai risultati: non dimostrano da soli che qualcuno abbia attaccato il sistema. La scansione risulta inoltre non autenticata (Auth Fail), quindi offre meno visibilità sullo stato dei pacchetti installati e delle correzioni locali.

La gravità pratica varia da voce a voce. Le schermate mostrano tre evidenze dirette particolarmente forti: Nessus è riuscito ad autenticarsi su VNC con la password “password”; il test Ghostcat è indicato come sfruttato da Nessus; sulla bind shell il comando id ha restituito uid=0(root). Per gli altri finding, il report distingue tra servizio/configurazione rilevati e sfruttamento effettivamente dimostrato.

Come leggere i livelli di gravità

Livello	Lettura pratica
Critical	Impatto potenziale molto elevato; intervenire per primo. È una priorità, non la prova automatica di un attacco.
High	Debolezza seria da correggere con priorità; rischio legato anche a esposizione e condizioni descritte.
Medium	Configurazione o protocollo debole; pianificare la correzione dopo aver verificato necessità e compatibilità.
Low	Impatto più limitato; utile correggerlo nell'attività di hardening.

Risultati Critical

Ubuntu 8.04 fuori supporto

Nessus identifica Ubuntu Linux 8.04, la cui fine del supporto di sicurezza è indicata come 9 maggio 2013. La porta riportata è 80/tcp; questa associazione individua il servizio sul quale il plugin ha riportato il sistema, ma il problema è a livello di sistema operativo. Un sistema senza aggiornamenti del produttore può accumulare falle senza correzioni: non è una singola vulnerabilità né, da sola, la prova che sia stato eseguito un attacco.

Intervento: migrare a un sistema operativo ancora supportato e verificare la compatibilità delle applicazioni.

Nessus assegna CVSS v3 10.0.

Password VNC "password"

Il servizio VNC sulla porta 5900/tcp permette una sessione grafica remota. L'output Nessus dice esplicitamente che il login è riuscito usando la password "password"; nei dettagli compaiono anche "Default Account: true" ed "Exploited by Nessus: true". Questa è una prova diretta che, durante la scansione, il servizio ha accettato quella credenziale: chi avesse potuto raggiungere VNC avrebbe potuto accedere alla sessione grafica secondo i privilegi configurati.

Intervento: sostituire la credenziale con una password lunga e forte.

Nessus assegna CVSS v2 10.0.

Tomcat AJP - Ghostcat

Il connettore AJP13 è esposto sulla porta 8009/tcp. La descrizione Nessus parla di lettura/inclusione di file applicativi tramite AJP e specifica che, in determinate condizioni, un attaccante potrebbe caricare file JSP e arrivare all'esecuzione di codice. Nei dettagli appare "Exploited by Nessus: true" e l'output mostra la richiesta usata dal test. Ciò sostiene che il controllo del plugin è riuscito;

Intervento: aggiornare la configurazione AJP per richiedere l'autorizzazione e/o aggiornare il server Tomcat alla versione 7.0.100, 8.5.51, 9.0.31 o successiva.

Nessus assegna CVSS v3 9.8

SSL 2.0 e SSL 3.0 abilitati

Il plugin ha rilevato protocolli SSL obsoleti su due servizi: SSLv2 sulla porta 25/tcp (SMTP) e SSLv3 sulla 5432/tcp (PostgreSQL). La descrizione Nessus spiega che questi protocolli hanno debolezze crittografiche e possono esporre le sessioni ad attacchi di intercettazione. Il risultato prova che i servizi accettano quelle negoziazioni.

Intervento: consultare la documentazione dell'applicazione per disabilitare SSL 2.0 e 3.0. Usare invece TLS 1.2 (con suite di cifratura approvate) o versioni superiori.

Nessus assegna CVSS v3 9.8

Bind shell senza autenticazione

Sulla porta 1524/tcp è presente una shell remota. L'output Nessus dice che il plugin ha eseguito il comando id e ha ricevuto "uid=0(root) gid=0(root) groups=0(root)", al momento della scansione un collegamento alla shell ha consentito l'esecuzione di un comando con privilegi root..

Intervento: verificare se l'host remoto è stato compromesso e reinstalla il sistema se necessario.

Nessus assegna CVSS v3 9.8

Debian/OpenSSL: generatore chiavi debole(controllo SSL)

Il plugin segnala il difetto storico del generatore casuale di Debian/Ubuntu, alcune chiavi crittografiche generate con quel software possono essere prevedibili. Il risultato è associato alle porte 25/tcp (SMTP) e 5432/tcp (PostgreSQL).

Intervento: controllare certificati e chiavi TLS dei servizi indicati e sostituire il materiale crittografico potenzialmente interessato, generando le nuove chiavi con software corretto.

Nessus assegna CVSS v2 10.0

Debian/OpenSSL: generatore chiavi debole

È lo stesso problema storico di generazione casuale debole, qui associato alla chiave host SSH sulla porta 22/tcp. Una chiave pubblica prevedibile può rendere non affidabile l'identità del server e, secondo la chiave coinvolta e il protocollo, indebolire la protezione delle sessioni.

Intervento: considerare tutto il materiale crittografico generato sull'host remoto come facilmente indovinabile. In particolare, tutto il materiale relativo alle chiavi SSH, SSL e OpenVPN dovrebbe essere rigenerato.

Nessus assegna CVSS v2 10.0

Risultati High

High indica una debolezza significativa da correggere con priorità.

Samba Badlock

La versione di Samba in esecuzione sull'host remoto è interessata da una vulnerabilità, nota come Badlock, presente nei protocolli Security Account Manager (SAM) e Local Security Authority (Domain Policy) (LSAD) a causa di una negoziazione errata del livello di autenticazione sui canali RPC (Remote Procedure Call). Un attaccante che effettui un attacco di tipo "man-in-the-middle" e sia in grado di intercettare il traffico tra un client e un server che ospita un database SAM può sfruttare tale vulnerabilità per forzare un declassamento del livello di autenticazione; ciò consente l'esecuzione di chiamate di rete Samba arbitrarie nel contesto dell'utente intercettato, come ad esempio la visualizzazione o la modifica di dati di sicurezza sensibili nel database Active Directory (AD) o la disabilitazione di servizi critici.

Intervento: aggiornare Samba a versione 4.2.11 / 4.3.8 / 4.4.2 o successiva.

Nessus assegna CVSS v3 7.5

Servizio rlogin esposto

Nessus rileva rlogin sulla porta 513/tcp. Il plugin spiega che il traffico passa in chiaro: credenziali e dati della sessione possono essere osservati sulla rete. Descrive inoltre condizioni in cui spoofing o indovinamento dei numeri di sequenza possono facilitare l'aggiornamento dell'autenticazione e cita i file .rhosts come possibile via per ottenere accesso.

Intervento: Commenta la riga 'login' in /etc/inetd.conf e riavvia il processo inetd. In alternativa, disabilita questo servizio e utilizza invece SSH.

Nessus assegna CVSS v2 7.5

Servizio rsh esposto

rsh è rilevato sulla porta 514/tcp. Come rlogin, trasmette dati senza la protezione crittografica di SSH e può dipendere da regole di fiducia; il plugin cita il rischio di intercettazione, autenticazione debole e accesso tramite .rhosts/hosts.equiv.

Intervento: commentare la riga relativa a 'rsh' nel file /etc/inetd.conf e riavviare il processo inetd. In alternativa, disabilitare il servizio e utilizzare SSH.

Nessus assegna CVSS v2 7.5

Condivisione NFS senza restrizioni

La porta 2049/tcp (RPC-NFS) esporta la condivisione senza restrizioni di accesso.

Intervento: applicare le restrizioni appropriate a tutte le condivisioni NFS.

Risultati Medium

Medium segnala configurazioni o protocolli che possono aumentare il rischio, spesso in base a esposizione, client e possibilità di intercettare il traffico..

TLS 1.0 abilitato

Il servizio remoto accetta connessioni crittografate tramite TLS 1.0. Il protocollo presenta diverse vulnerabilità di progettazione crittografica. Sebbene le implementazioni moderne di TLS 1.0 mitigano tali problemi, le versioni più recenti di TLS, come la 1.2 e la 1.3, sono progettate per prevenire queste vulnerabilità e dovrebbero essere utilizzate ove possibile. A partire dal 31 marzo 2020, gli endpoint non abilitati per TLS 1.2 o versioni successive non funzioneranno più correttamente con i principali browser web e con i sistemi dei principali vendor. Lo standard PCI DSS v3.2 richiede la disabilitazione completa di TLS 1.0 entro il 30 giugno 2018, fatta eccezione per i terminali POS/POI (e i relativi punti di terminazione SSL/TLS) per i quali sia possibile verificare l'assenza di vulnerabilità a exploit noti.

Intervento: abilitare il supporto per TLS 1.2 e 1.3 e disabilitare il supporto per TLS 1.0.

Telnet non cifrato

L'host remoto esegue un server Telnet su un canale non crittografato. L'utilizzo di Telnet su un canale non crittografato è sconsigliato, poiché nomi utente, password e comandi vengono trasmessi in chiaro. Ciò consente a un attaccante remoto di intercettare la sessione Telnet per ottenere credenziali o altre informazioni sensibili e di modificare il traffico scambiato tra client e server.

SSH è preferibile a Telnet, in quanto protegge le credenziali dalle intercettazioni e consente di incapsulare (tunneling) ulteriori flussi di dati, come ad esempio una sessione X11.

Intervento: disabilitare Telnet e usare SSH.

Nessus assegna CVSS v3: 6.5

DROWN: SSLv2 e cipher export

L'host remoto supporta SSLv2 e potrebbe quindi essere soggetto a una vulnerabilità che consente un attacco "cross-protocol Bleichenbacher padding oracle" noto come DROWN (Decrypting RSA with Obsolete and Weakened eNcryption). Tale vulnerabilità deriva da un difetto nell'implementazione di Secure Sockets Layer versione 2 (SSLv2) e permette la decrittazione del traffico TLS intercettato. Un attaccante che opera un attacco "man-in-the-middle" può sfruttare questa falla per decrittare la connessione TLS utilizzando traffico precedentemente intercettato e crittografia debole, unitamente a una serie di connessioni appositamente predisposte verso un server SSLv2 che impiega la stessa chiave privata.

Intervento: disabilitare SSLv2 e i cipher export/deboli; verificare che la stessa chiave privata non sia utilizzata tra servizi o protocolli che accettano SSLv2.

Nessus assegna CVSS v3 5.9

Cipher SSL anonimi supportati

L'host remoto supporta l'uso di cifrari SSL anonimi. Sebbene ciò consenta a un amministratore di configurare un servizio che crittografa il traffico senza dover generare e configurare certificati SSL, non offre alcun modo per verificare l'identità dell'host remoto e rende il servizio vulnerabile ad attacchi di tipo man-in-the-middle.

Nota: la vulnerabilità è decisamente più facile da sfruttare se l'attaccante si trova sulla stessa rete fisica.

Intervento: Riconfigurare l'applicazione interessata, se possibile, per evitare l'uso di cifrari deboli.

Nessus assegna CVSS v3: 5.9.

Risultati Low

Low indica un impatto più contenuto rispetto alle voci precedenti, ma i risultati sono comunque utili per ridurre esposizione e facilitare la ricognizione.

Diffie-Hellman debole - Logjam

L'host remoto consente connessioni SSL/TLS che utilizzano uno o più moduli Diffie-Hellman di dimensioni pari o inferiori a 1024 bit. Attraverso la crittoanalisi, un terzo potrebbe riuscire a determinare il segreto condiviso in tempi brevi (a seconda della dimensione del modulo e delle risorse a disposizione dell'attaccante). Ciò potrebbe consentire a un attaccante di recuperare il testo in chiaro o potenzialmente di compromettere l'integrità delle connessioni.

Sulla porta 25/tcp SMTP, Nessus mostra un gruppo Diffie-Hellman MODP da 512 bit e indica difficoltà Logjam "Easy"; elenca anche una suite export. Moduli così piccoli rendono più debole lo scambio di chiavi e, nelle condizioni descritte dal plugin, possono facilitare attacchi alla comunicazione.

Intervento: riconfigurare il servizio affinché utilizzi moduli Diffie-Hellman di dimensioni pari o superiori a 2048 bit.

Nessus assegna CVSS v

X Server Detection

Nessus identifica un server X11 versione 11.0 sulla porta 6000/tcp. Il protocollo permette a client remoti di interagire con applicazioni grafiche e, se esposto o non cifrato, può rilevare il traffico della sessione. Il risultato conferma il server rilevato, ma non mostra un accesso grafico riuscito. Poiché il traffico X11 non è crittografato, un attaccante potrebbe intercettare la connessione.

Intervento: limitare l'accesso alla porta alla rete strettamente necessaria; se X11 non serve da remoto, disabilitare l'ascolto TCP.

Nessus assegna CVSS v2 2.6.

Risposta ICMP Timestamp

L'host remoto risponde a una richiesta di timestamp ICMP. Ciò consente a un attaccante di conoscere la data impostata sulla macchina bersaglio, informazione che può aiutare un attaccante remoto non autenticato a eludere i protocolli di autenticazione basati sul tempo.

I timestamp restituiti dalle macchine che eseguono Windows Vista, 7, 2008 o 2008 R2 sono deliberatamente errati, ma solitamente differiscono di meno di 1000 secondi dall'ora effettiva del sistema.

Intervento: filtrare le richieste ICMP Timestamp di tipo 13 e le risposte di tipo 14 se non sono necessarie.

Nessus assegna CVSS v2: 2.1; la discrepanza mostrata è di circa 2 secondi.